网安复习 dww副本

第1章 网络空间安全概述

1.1 信息时代与信息安全

- 信息技术与产业空前繁荣
  - 人类文明的发展历程
  - 信息时代的特征
  - 新摩尔定律
  - 吉尔德定律
  - 千倍定律
  - 我国已经成为信息技术与产业大国
  - 量子信息技术高速发展
  - 中国的量子信息技术
- 信息安全形势严峻
  - 敌对势力的破坏
  - 黑客攻击
  - 计算机病毒
  - 利用计算机进行经济犯罪
  - 有害内容泛滥、隐私保护问题严重
  - 信息战、网络战
  - 信息技术进步对信息安全的挑战
  - 基础信息产品严重依赖国外
- 我国重视信息安全

1.2 网络空间安全学科浅谈

- 网络空间与网络空间安全的概念
  - 网络空间
  - 我们的观点
  - 信息论的基本观点
  - 网络空间存在更突出的信息安全问题
- 网络空间安全学科内涵
  - 信息安全是信息对其生存环境的基本要求

    - 设备安全
    - 数据安全
    - 行为安全
    - 内容安全
    - 安全措施
    - 技术措施
    - 信息安全三大定律
    - 信息安全的普遍性定律
    - 信息安全的折中性定律
    - 信息安全的就低性定律
    - 绝对的安全是不存在的
    - 安全的目的
    - 网络空间安全学科定义
- 学科主要研究方向及内容
    - 密码学
    - 网络安全
    - 系统安全
    - 信息内容安全
    - 信息对抗
- 学科的理论基础
    - 数学
    - 信息论
    - 系统论
    - 控制论
    - 计算理论
    - 密码学理论
    - 访问控制理论
- 学科的方法论
    - 方法论基础
    - 逆向分析

1.3 网络空间安全法律法规

- 我国信息安全立法现状
    - 信息安全法律法规

    - 我国有关信息安全的主要法律和行政法规
- 计算机犯罪有关刑法条款
    - 计算机犯罪有关《刑法》的法律条款
- 互联网安全的刑事责任
- 国家网络安全法
    - 中华人民共和国网络安全法
- 国家密码法
    - 中华人民共和国密码法
    - 什么是密码
    - 谁来管密码
    - 怎么管密码
    - 怎么用密码
- 信息安全系统保护条例
    - 中华人民共和国计算机信息系统保护条例

1.4 信息安全标准

- 技术标准的基本知识
    - 标准的定义
    - 信息安全标准
- 信息安全有关的主要标准化组织
    - 国际电工委员会
    - 国际标准化组织
    - 信息安全技术委员会
    - 国际电信联盟
    - 电气与电子工程师协会
    - 美国国家标准学会
    - 美国国家标准与技术研究院
- 我国信息安全标准组织
    - 全国信息安全标准化技术委员会
    - 密码行业标准化技术委员会
- 信息安全标准
    - 《涉及国家秘密的信息系统分级保护管理办法》
    - 涉密信息系统分级保护相关标准
    - 信息系统安全等级保护基本要求

- 商用密码标准
- ZUC祖冲之密码算法标准
- SM2密码算法标准
- SM3密码杂凑算法标准
- SM4分组密码算法标准
- SM9标识密码算法标准

第2章 密码学基础1

2.1.1 密码的发展

- 密码学发展的四个阶段
- 消息隐藏与隐写术
- 斯巴达密码棒
- 达·芬奇密码筒

2.1.2 古典密码

- 古典密码的基本方法
- 恺撒密码
- 维吉尼亚密码
- 普莱费尔密码
- 置换密码
- 栅格换位
- 矩形换位
- 费纳姆密码
- 一次一密密码
- 扩散与混淆

2.1.3 机械密码

- Enigma密码机
- Enigma的内部构造与工作原理
- Enigma的密钥设置
- Enigma的破译
- 紫色密码机
- 其他机械密码机

2.1.4 现代密码学

- 现代密码理论的基础
- 保密通信系统的数学模型
- 信息隐藏与信息保密
- 现代密码学的应用
- 单钥密码体制
- 序列密码
- 分组密码
- Feistel网络
- DES数据加密标准
- DES工作模式
- DES安全性分析
- AES高级加密标准
- 公钥密码体制
- 单向函数与单向陷门函数
- Diffie-Hellman密钥交换协议
- RSA密码体制
- ECC椭圆曲线密码体制
- 单钥密码体制与公钥密码体制的比较
- 密码技术分支
- 密码体制五大特性
- 量子密码基础
- BB84量子密钥分发协议

2.1.5 密码学面临的挑战

- 云计算与云存储对密码学的挑战
- 大数据对密码学的挑战
- 物联网对密码学的挑战
- 量子计算机对密码学的挑战
- 区块链技术对密码学的挑战

第3章 密码学基础2

2.2.1 密码体制分类

- 密码学基本概念
- 密码体制的语法定义
- 保密系统模型
- 单钥密码体制
- 双钥密码体制

2.2.2 密码分析

- 密码分析与密码设计
- 密码的安全性
- 密码攻击类型
  - 唯密文攻击
  - 已知明文攻击
  - 选择明文攻击
  - 选择密文攻击
- 密码分析方法
  - 穷举攻击
  - 数学攻击
  - 物理攻击
  - 侧信道攻击

2.2.3 密码学基本数学知识

- 整数分解
- 模运算
- 群、环与域
- 有限域
- 欧几里得算法
- 中国剩余定理
- 椭圆曲线
  - 实数域上的椭圆曲线
  - 椭圆曲线上的加法
  - 有限域上的椭圆曲线

2.2.4 国内外密码算法概览

- 序列密码
  - 序列密码原理

    - 密钥流生成器
    - 伪随机序列
    - 序列密码的软硬件实现算法
- 分组密码
    - 分组密码的概念
    - 分组密码的设计要求
    - 扩散与混淆
- 公钥密码体制
    - 公钥密码思想的提出
    - 公钥密码体制的原理
    - 公钥加密方案
    - 公钥密码体制的特点
    - 公钥密码体制的用途
    - 公钥密码体制的安全性
- RSA算法
    - RSA算法的使用及特点
    - RSA算法的安全性
- Rabin公钥密码算法
- ElGamal公钥密码算法
- 椭圆曲线公钥密码算法
- 国产密码
    - SM1、SM4、SM7和ZUC
    - SM2和SM9
    - SM3

第4章 消息鉴别

4.1 消息鉴别概述

- 消息篡改类型
- 单纯加密的局限性
- 加密结合校验

4.2 基于消息鉴别码的鉴别方法

- 基本思想

- MAC的作用
- MAC函数与加解密函数的比较
- 基于MAC的鉴别方法分类
- 基于消息加密的MAC鉴别方法
- 基于单向Hash函数和对称密钥体制的MAC鉴别方法
- 基于单向Hash函数和公钥密码体制的MAC鉴别方法
- 基于秘密数据块和单向Hash函数的MAC鉴别方法
- MAC函数特性
- MAC函数强行攻击过程
- MAC函数强行攻击难度
- MAC函数的设计要点

4.3 单向散列函数

- 函数参数与特性
- 散列函数的生日攻击
- 生日悖论
- 单向散列函数常用设计方法
- 常用单向散列函数

4.4 单向散列函数：MD5算法

- 基本描述
- 算法过程结构
- 填充比特位
- 附加消息长度
- 初始化寄存器
- 计算散列值
- MD5的安全性
- 冲突（碰撞）的定义与生日悖论
- 散列函数的通用结构（Merkle-Damgård结构）
- 安全散列算法（SHA-1、SHA-2、SHA-3）核心参数与对比
- 国产商用密码算法：SM3密码散列算法

4.4 报文摘要算法（MD5）

- MD5算法概述与核心参数
- MD5算法过程结构

- MD5步骤1：填充比特位
- MD5步骤2：附加消息长度
- MD5步骤3：初始化寄存器
- MD5步骤4：HMD5基本循环（四轮变换与逻辑函数）
- MD5步骤5：散列值输出
- MD5变换函数、步函数与单步逻辑结构
- MD5算法的安全性分析（王小云教授团队的碰撞攻击）

第5章 数字签名

数字签名概述

- 数字签名的真实性要求
- 数字签名与消息鉴别的区别
- 手写签名的特性
- 数字签名的设计目标
- 数字签名的特性
- 数字签名主要算法

基于RSA的数字签名

- RSA加密与签名
- RSA签名的特点
- 具有保密特性的RSA签名
- 结合消息摘要的数字签名

数字签名标准DSS

- DSS初始化
- DSA签名过程
- DSA验证过程
- DSA正确性证明
- RSA与DSA的比较

5.4 其他签名模式

- 不可否认签名
- 盲签名
- 群签名

- 代理签名
- 指定证实人签名

第6章 信息隐藏

6.1 信息隐藏概述

- 数字化产品的保护问题
- 加密、签名技术存在的局限
- 信息隐藏内涵
- 信息隐藏分类
- 隐秘信道
- 伪装术
- 匿名通信
- 数字水印定义

6.2 数字水印的特性

- 可证明性
- 鲁棒性
- 透明性
- 安全性

6.3 数字水印的分类

- 按可见与否分类
- 按水印添加方式分类
- 按水印检测方式分类

6.4 数字水印嵌入过程

- 水印生成
- 水印嵌入
- 水印的提取/检验
- 水印提取模型
- 水印检验模型

6.5 空域水印技术

- 空域水印的含义

- 空域水印典型方法
- LSB方法
- LSB方法特点
- Patchwork方法
- Patchwork方法特点

6.6 χ^2分析

- χ^2分析原理
- χ^2分析统计效果示例

6.7 直方图补偿隐写

- 直方图补偿隐写原理
- 直方图补偿隐写特点

6.8 RS分析方法

- RS分析基本流程
- 翻转函数定义
- 非负翻转相关计算
- 非正翻转相关计算
- RS分析关键结论
- RS分析实验
- RS分析检测方法

6.9 改进的LSB隐写

- 改进LSB隐写思路
- 隐写规则调整
- 抗RS分析性能
- 抗卡方分析性能

6.10 变换域水印

- 变换域水印主要方法
- 变换域水印主要特点
- 变换域水印基本过程
- DCT水印方案嵌入过程
- DCT水印检验过程
- 变换域算法

只求简单快速，选空域；要求抗压缩、抗处理、抗攻击，选变换域。

第7章 密钥管理

密钥管理概述

- 密钥管理的必要性
- 密钥的生存期
- 密钥管理的概念
- 密钥管理的核心内容

密钥生成技术

- 密钥的随机性与密码特性
- 弱密钥
- 密钥长度与破解时间
- 字典攻击
- 密钥产生模式
- 密钥自动产生方法

密钥建立技术

- 密钥协商协议
- 密钥分配协议
- 对称密钥建立
- 公开密钥建立
- Diffie-Hellman协议
- 对称密钥分配方法
- 基于公钥的密钥协商协议
- 基于KDC的对称密钥分配协议
- BB84量子密钥分配协议

密钥存储技术

- 密钥整体保存
- 密钥分散保存
- 门限密钥存储技术
- Shamir门限方案
- 共享分配过程
- 密钥恢复过程

- 拉格朗日内插值法

第8章 密码学基础3

2.3.1 身份基公钥密码

- 身份基公钥密码的基本思想
- 私钥生成中心PKG
- 身份基加密
- 身份基签名
- 身份基公钥密码的优缺点

2.3.2 属性基公钥密码

- 属性基加密
- 属性权威AA
- 属性基加密机制
- 密钥策略属性基加密
- 密文策略属性基加密
- 属性基签名（特点）
- 属性基公钥密码的相关研究（性质）

2.3.3 同态密码

- 同态密码的提出
- 同态密码的发展阶段
- 同态密码技术的应用
- 同态密码技术的优缺点

2.3.4 抗量子密码

- 基于量子物理学的量子密码
- 基于生物学的DNA密码
- 基于数学的抗量子计算密码
- 基于格的密码
- 基于Hash的数字签名
- 基于纠错编码的密码
- 基于多变量的密码

2.3.5 轻量级密码

- 轻量密码的特性
- 轻量密码的设计与实现
- 轻量密码的性能评估
- 轻量级密码的研究现状

2.4 密码学主要研究方向

- 密码理论
- 密码工程与应用
- 密码管理
- 密码安全防护
- 量子密码

第9章 网络攻击

9.1 网络攻击基础

- 网络攻击的概念
- 网络攻击的分类
- 系统漏洞形成原因
- 系统漏洞分类
- 攻击的一般流程

9.2 系统安全漏洞扫描

- 网络安全扫描阶段
- 网络安全扫描技术
- 典型扫描案例
- 常见的扫描类型
- 常见的扫描工具介绍

9.3 网络监听

- 网络监听概述
- 局域网中的硬件设备简介
- 共享式局域网监听
- 交换式局域网监听
- ARP欺骗

- 其他网络欺骗
- 网络监听的检测和防范
- 常见的网络监听工具

9.4 拒绝服务攻击

- 拒绝服务攻击概述
- DoS攻击分类思路
- 常见的DoS攻击
- 分布式拒绝服务攻击（DDoS）
- 拒绝服务攻击的防范

9.5 缓冲区溢出攻击

- 缓冲区溢出攻击概述
- 进程的内存映像
- 数据段缓冲区溢出攻击示例
- 函数调用缓冲区溢出攻击示例
- 缓冲区溢出成因
- 缓冲区溢出漏洞现状
- 缓冲区溢出的防范

9.6 SQL注入攻击

- SQL注入攻击概述
- SQL注入攻击的原理
- SQL注入攻击的一般步骤
- SQL注入攻击的防范

9.7 计算机病毒与恶意软件

- 计算机病毒与恶意软件概述
- 计算机病毒概述
- 计算机病毒的特性
- 计算机病毒程序模块构成
- 计算机病毒检测方法
- 木马概述

第10章 防火墙

防火墙概念

- 防火墙的定义
- 网络安全区域
- 防火墙的作用
- 防火墙的典型使用形态
- 防火墙的特性
- 防火墙的基本原理
- 防火墙的性能指标
- 防火墙的优缺点
- 防火墙的发展

防火墙技术

- 包过滤技术
- 应用代理
- 状态检测技术

包过滤技术

- 包过滤原理
- 包检查内容
- IP、TCP和UDP报文
- 包过滤规则
- 地址过滤
- 服务与端口过滤
- 包过滤实例
- IP包过滤特性
- TCP包过滤特性
- UDP包过滤特性
- UDP动态数据包过滤
- 数据包过滤的风险
- 包过滤防火墙的优缺点

代理技术

- 代理技术的基本思想
- 应用层网关
- 电路网关

- 应用层网关的基本原理
- 应用层网关的内部结构
- 代理防火墙的优缺点
- 自适应代理防火墙

状态检查与地址转换

- 状态检查技术
- 地址翻译技术NAT
- 静态翻译
- 动态翻译
- 端口转换

防火墙的体系结构

- 屏蔽路由器
- 双宿主机网关
- 屏蔽主机网关
- 屏蔽子网网关
- DMZ隔离区

第11章 入侵检测

11.1 入侵检测基础概述

- 网络安全威胁类型
- 攻击复杂度与攻击者技术水平演变
- 传统安全技术局限性
- 入侵检测定义
- 入侵检测系统IDS
- 入侵检测的目的
- 入侵检测的起源
- 入侵检测系统的需求特性
- 入侵检测性能关键参数

11.2 入侵检测工作流程与模型

- 入侵检测的一般过程
- 信息收集

- 信息分析
- 结果处理
- 入侵检测系统通用CIDF模型

11.3 入侵检测系统分类（按数据来源）

- 基于主机的入侵检测HIDS
- HIDS工作原理
- HIDS检测内容
- HIDS优缺点
- 基于网络的入侵检测NIDS
- NIDS工作原理
- NIDS检测内容
- NIDS优缺点
- 主机IDS与网络IDS对比

11.4 入侵检测分析方法

- 异常检测
- 异常检测示例
- 异常检测的优缺点
- 误用检测
- 误用检测的优缺点
- 误用检测与异常检测的比较

11.5 网络入侵检测系统实例

- 网络抓包相关技术
- 数据包分析
- 协议分析
- 模式匹配

第12章 身份认证

12.1 身份认证概述

- 身份认证的必要性
- 身份认证概念
- 身份认证依据的来源

- 认证技术
- 认证模式
- 身份证明系统的组成和要求
- 身份认证系统的特征

12.2 基于口令的身份认证

- 口令认证的缺陷
- 口令认证的方式
- 静态口令
- 动态口令
- 动态口令产生的基本原理
- 动态口令常用技术
- 挑战/应答口令原理
- S/Key原理
- S/Key使用过程

12.3 基于密码技术的鉴别方法

- 基于对称密码的身份鉴别
- 基于公钥密码技术的鉴别
- Kerberos协议介绍
- Kerberos认证模型

12.4 基于零知识证明的身份认证

- 零知识证明基本概念
- 最小泄露协议与零知识证明协议性质
- 零知识洞穴
- 零知识洞穴协议分析
- 基于离散对数的零知识证明
- 基于离散对数的零知识证明协议分析

12.5 基于生物特征的身份认证技术

- 手书签字验证
- 指纹验证
- 语音验证
- 视网膜图样验证
- 虹膜图样验证

- 人脸识别
- 步态识别

第13章 区块链

13.1 区块链概述

- 区块链定义
- 分布式可信账本
- 区块链的起源
- 中心化的弊端
- 开放环境下的安全问题

13.2 区块链的主要特性

- 去中心化
- 开放与共识
- 交易透明、双方匿名
- 不可篡改、可追溯

13.3 区块链的基本原理

- 区块链数据结构
- 区块数据项说明
- Hash指针
- Merkle梅根树
- SPV交易验证过程
- 比特币交易模型UTXO
- 比特币交易实例
- 比特币交易解锁验证
- 比特币地址生成
- 交易产生过程
- POW工作量证明原理
- 分叉解决机制
- 51%攻击问题
- 区块链网络
- 比特币节点功能

13.4 基于区块链的比特币不足

- 比特币优势
- 比特币存在的不足

13.5 区块链的主要类别

- 公有链
- 私有链
- 联盟链

13.6 常用数字货币平台

- 主流区块链平台介绍

计算题

密码学基础1

代换密码

单表代换 —— 恺撒密码

☆练习 1

解决密钥分配问题的一个办法是使用收发双方都有的一本书中某行文字。至少在某些侦探小说中经常把一本书的第一句话作为密钥。

给定下列消息：

SIDKHKDMAF HCRKIABIE SHIMC KD LFEAILA

这段密文是用《沉默的背后》(The Other Side Silence)一书的第一句话和单表代替方法产生的，使用的是简单的代替密码，这句话是

The snow lay thick on the steps and the snowflakes driven by the wind looked black in the headlights of the cars.

(1) 根据以上密文和密钥求原文消息。

(2) 为了使密钥分配问题简单化，通信双方都同意使用一本书的第一句话或最后一句话作为密钥。要想改变密钥，他们只需更换一本书就行了。使用第一句话比使用最后一句话要好，为什么?

密文：A B C D E F G H I J K L M N O P Q R S T U V W X Y Z

明文：T H E S N O W L A Y I C K P D F R V B G J M Q U X Z

（1）明文句子：BASILISK TO LEVIATHAN: BLAKE IS CONTACT

（2）使用第一句话更方便、更可靠。双方拿到同一本书后，只要翻到开头就能立刻得到密钥，不需要查找书的结尾。不同版本的书可能会有后记、附录、出版说明等内容，导致“最后一句话”不一定一致，容易产生密钥不统一的问题。而第一句话通常更稳定、更容易确认，所以更适合作为密钥。

多表代换 —— 维吉尼亚密码

这题是维吉尼亚密码加密cybersecurity, 密钥是course

维吉尼亚密码——加密方法

可对英文字母表进行编号，把A—Z依次编为0—25。通过计 算明文字母与密钥字母的模26加得到密文字母。以明文data security，密钥best为例：

明文	d	a	t	a	s	e	c	u	r	i	t	y
编码	3	0	19	0	18	4	2	20	17	8	19	24
密钥	b	e	s	t	b	e	s	t	b	e	s	t
编码	1	4	18	19	1	4	18	19	1	4	18	19
模26加	4	4	11	19	19	8	20	13	18	12	11	17
密文	e	e	l	t	t	i	u	n	s	m	l	r

明文：datasecurity　　密文：eelttiunsmlr

emvvjwgqoiaxa

☆练习 3

采用维吉尼亚密码一次一密版本的用途。该方案中，密钥是位于 0～26 的随机数字。例如，如果密钥时 3 19 5，则明文的第一个字母使用 3 个字母的移位加密，第二个字母使用 19 个字母的移位加密，第三个字母使用 5 个字母的移位加密，以此类推。

(1) 使用密钥流 9 1 7 23 15 21 14 11 11 2 8 9 加密明文 sendmoremoney.

(2) 使用(1)中产生的密文找到一个密钥，以便该密文解密为 cashnotneeded.

密钥是`9 0 1 7 23 15 21 8 11 11 2 8 9`

答案：

(1) BEOKJDMMXZPMH

(2) 25 4 22 3 22 15 19 25 19 21 12 8 4

注意加减法：明文+key=密文

多字母代换 —— 普莱费尔密码

3. 多表替换密码-普莱费尔密码

☆练习 4

已知密钥为 occurrence，使用普莱费尔密码加密以下消息：

Must see you over Cadogan West.Coming at once

参考答案：

1. 明文分组：mu,st,se,ey,ou,ov,er,ca,do,ga,nw,es,tc,om,in,ga,to,nc,ex(X 为补位)
2. 构造矩阵：

O	C	U	R	E
N	A	B	D	F
G	H	I/J	K	L
M	P	Q	S	T
V	W	X	Y	Z

答案：

代码块

```
O   C   U   R   E
N   A   B   D   F
G   H   I/J K   L
M   P   Q   S   T
V   W   X   Y   Z

mu → QO
st → TM
se → TR
ey → RZ
ou → CR
ov → NO
er → OE
ca → AH
do → NR
ga → HN
nw → AV
es → RT
tc → PE
om → NV
in → GB
ga → HN
to → ME
nc → AO
ex → UZ

QO TM TR RZ CR NO OE AH NR HN AV RT PE NV GB HN ME AO UZ
```

已知密钥为 Tuesday，使用普莱费尔密码加密消息 M 得到如下密文：

FBIBXTSBTVGECV

答案：

```
FB → CY
IB → BE
XT → RS
SB → EC
TV → UR
GE → IT
CV → YX
```

1. 已知普莱费尔密码的密钥为 CRYPTO，密文为 ZFQMBN，请按以下规则解密：

1) 构建 5×5 密钥矩阵（I/J 合并，密钥去重后填充剩余字母）；
2) 按普莱费尔解密规则（同行取左侧、同列取上侧、矩形取对角）还原明文
3) 去除明文末尾补的 X，整理最终明文。

构建 5×5 密钥矩阵

```
C  R  Y  P  T
O  A  B  D  E
F  G  H  I  K
L  M  N  Q  S
U  V  W  X  Z
```

密文分组

密文：`ZFQMBN`

```
ZF → UK
QL → NL
BN → YH
```

合并明文

```
ZF   QM   BN
UK   NL   YH
```

得到：

```
1  UKNLYH
```

末尾没有补位的 **X**，所以不用删除。

置换密码 —— 栅格换位和矩形换位

费纳姆密码和一次一密密码

DES

https://www.bilibili.com/video/BV1Z94y1P7sh?spm_id_from=333.788.recommend_more_video.0&trackid=web_related_0.router-related-2589621-z4htq.1780887279559.282&vd_source=a9ab34f287effc918ec339427d6b07ed



利用 DES 算法和全 0 密钥对输入 10000001 19600000 进行一次加密的结果

DES 一轮公式是：

```
1  L1 = R0
2  R1 = L0 ⊕ f(R0, K1)
```

PPT 里 DES 轮结构就是这种 Feistel 结构：左边直接变成上一轮右边，右边等于上一轮左边异或轮函数结果；轮函数中包含扩展 E、与子密钥异或、S 盒压缩、P 置换。

题目给的是：

```
代码块
1   输入：10000001 19600000
2   密钥：全 0
```

把输入分成左右两半：

```
代码块
1   L0 = 10000001
2   R0 = 19600000
```

全 0 密钥时，本题一轮用的子密钥可以看成：

```
代码块
1   K1 = 000000000000
```

注意这里 `K1` 是 48 bit，也就是 12 个十六进制 0。

第一步：算 L1

根据 DES 一轮公式：

```
代码块
1   L1 = R0
```

所以：

```
代码块
1   L1 = 19600000
```

这就是参考答案前半部分为什么是 `19600000`。

第二步：算 f(R0, K1)

现在要算：

```
代码块
```

```
f(19600000, 000000000000)
```

DES 的 f 函数流程是：

代码块

```
R0 经过 E 扩展置换：32 bit → 48 bit
再与子密钥 K1 异或
再经过 8 个 S 盒：48 bit → 32 bit
最后经过 P 置换
```

对 R0 做 E 扩展

代码块

```
R0 = 19600000
```

写成二进制：

代码块

```
00011001 01100000 00000000 00000000
```

经过 DES 的 E 扩展置换后得到 48 bit：

代码块

```
E(R0) = 0F2B00000000
```

写成 8 组，每组 6 bit：

代码块

```
000011 110010 101100 000000 000000 000000 000000 000000
```

与全 0 子密钥异或

代码块

```
E(R0) = 0F2B00000000
K1    = 000000000000
```

异或后还是它本身：

```
代码块
1   E(R0) ⊕ K1 = 0F2B00000000
```

也就是：

```
代码块
1   000011 110010 101100 000000 000000 000000 000000 000000
```

进入 8 个 S 盒

每 6 bit 进一个 S 盒，输出 4 bit。

S 盒	输入	输出十进制	输出二进制
S1	11	15	1111
S2	110010	8	1000
S3	101100	3	11
S4	0	7	111
S5	0	2	10
S6	0	12	1100
S7	0	4	100
S8	0	13	1101

所以 S 盒输出合起来是：

```
代码块
1   1111 1000 0011 0111 0010 1100 0100 1101
```

转成十六进制：

```
代码块
1   F8372C4D
```

再做 P 置换

输出第1位 = 输入第16位 = 1

输出第2位 = 输入第7位 = 0

输出第3位 = 输入第20位 = 0

输出第4位 = 输入第21位 = 1

```
代码块
1   P(F8372C4D) = 9CD89AAE
```

所以：

```
代码块
1   f(R0, K1) = 9CD89AAE
```

第三步：算 R1

公式：

```
代码块
1   R1 = L0 ⊕ f(R0, K1)
```

代入：

```
代码块
1   L0          = 10000001
2   f(R0, K1)  = 9CD89AAE
```

异或：

```
代码块
1   10000001
2   ⊕ 9CD89AAE
3   = 8CD89AAF
```

所以：

```
代码块
1   R1 = 8CD89AAF
```

最终答案

```
代码块
1   L1 = 19600000
2   R1 = 8CD89AAF
```

合起来：

```
代码块
1   19600000 8CD89AAF
```

所以参考答案：

```
代码块
1   19600000 8cd89aaf
```

是正确的。

你可以在作业里这样写最简过程：

```
代码块
1   L0 = 10000001, R0 = 19600000
2   K1 = 000000000000
3
4   E(R0) = 0F2B00000000
5   E(R0) ⊕ K1 = 0F2B00000000
6
7   S盒输出 = F8372C4D
8   P置换后 f(R0,K1) = 9CD89AAE
9
10  L1 = R0 = 19600000
11  R1 = L0 ⊕ f(R0,K1)
12     = 10000001 ⊕ 9CD89AAE
13     = 8CD89AAF
14
15  所以一轮加密结果为：
16  19600000 8CD89AAF
```

假设密文和密钥的各位全为 1，计算 DES 解密时第一轮输出中的 1 位，16，33，48 位

DES 解密和加密结构一样，只是子密钥顺序反过来使用。DES 本身是 64 bit 分组，先做 IP，再进行 16 轮 Feistel 迭代。PPT 里也说明 DES 是 64 bit 输入、64 bit 输出，并且流程为 IP、16 轮迭代、IP^{-1}；Feistel 解密公式是 `Ri-1 = Li`，`Li-1 = Ri ⊕ f(Li, Ki)`。

也就是十六进制：

```
代码块
```

```
C = FFFFFFFFFFFFFFFF
K = FFFFFFFFFFFFFFFF
```

先做 IP 初始置换

因为密文每一位都是 `1`，所以不管怎么置换，结果还是全 `1`。

代码块

```
IP(C) = FFFFFFFFFFFFFFFF
```

分成左右两半：

代码块

```
L0 = FFFFFFFF
R0 = FFFFFFFF
```

也就是：

代码块

```
L0 = 11111111 11111111 11111111 11111111
R0 = 11111111 11111111 11111111 11111111
```

解密第一轮公式

解密时第一轮用的是最后一轮子密钥 `K16`。

因为密钥全为 1，经过密钥置换和移位后仍然全为 1，所以：

代码块

```
K16 = 111111111111111111111111111111111111111111111111
```

也就是 48 位全 1。

第一轮公式：

代码块

```
L1 = R0
R1 = L0 ⊕ f(R0, K16)
```

所以：

代码块

```
R1 = FFFFFFFF
```

接下来重点算：

代码块

```
R1 = FFFFFFFF ⊕ f(FFFFFFFF, FFFFFFFFFFFF)
```

计算 f(R0, K16)

DES 的 f 函数流程：

代码块

```
R0 → E 扩展 → 与子密钥异或 → S 盒 → P 置换
```

3.1 E 扩展

因为：

代码块

```
R0 = FFFFFFFF
```

也就是 32 位全 1。

E 扩展只是重新取位，所以扩展后仍然全 1：

代码块

```
E(R0) = FFFFFFFFFFFF
```

这是 48 位全 1。

3.2 与 K16 异或

代码块

```
E(R0) = FFFFFFFFFFFF
K16   = FFFFFFFFFFFF
```

异或：

代码块

```
FFFFFFFFFFFF
⊕ FFFFFFFFFFFF
= 000000000000
```

所以进入 S 盒的是 48 位全 0：

代码块

```
000000 000000 000000 000000 000000 000000 000000 000000
```

查 S 盒

每 6 bit 进一个 S 盒，输出 4 bit。

因为 8 组输入都是：

代码块

```
000000
```

所以查每个 S 盒的第 0 行、第 0 列。

DES 标准 S 盒查表结果为：

代码块

```
S1(000000) = 1110
S2(000000) = 1111
S3(000000) = 1010
S4(000000) = 0111
S5(000000) = 0010
S6(000000) = 1100
S7(000000) = 0100
S8(000000) = 1101
```

合起来：

代码块

```
1110 1111 1010 0111 0010 1100 0100 1101
```

转成十六进制：

代码块

```
EFA72C4D
```

做 P 置换

对 S 盒输出：

```
代码块
1   EFA72C4D
```

做 DES 的 P 置换，得到：

```
代码块
1   P(EFA72C4D) = D8D8DBBC
```

所以：

```
代码块
1   f(R0, K16) = D8D8DBBC
```

计算 R1

```
代码块
1   R1 = L0 ⊕ f(R0, K16)
```

代入：

```
代码块
1   L0          = FFFFFFFF
2   f(R0,K16)   = D8D8DBBC
```

异或：

```
代码块
1   FFFFFFFF
2   ⊕ D8D8DBBC
3   = 27272443
```

所以第一轮输出为：

```
代码块
```

```
L1 = FFFFFFFF
R1 = 27272443
```

合起来：

代码块

```
第一轮输出 = FFFFFFFF 27272443
```

找第 1、16、33、48 位

把第一轮输出写成二进制：

代码块

```
FFFFFFFF 27272443
```

其中：

代码块

```
FFFFFFFF = 11111111 11111111 11111111 11111111
27272443 = 00100111 00100111 00100100 01000011
```

所以完整 64 位是：

代码块

```
11111111 11111111 11111111 11111111 00100111 00100111 00100100 01000011
```

编号从左到右，第 1 位到第 64 位。

第 1 位在 `L1` 里：

代码块

```
第 1 位 = 1
```

第 16 位也在 `L1` 里：

代码块

```
第 16 位 = 1
```

第 33 位是 `R1` 的第 1 位。`R1 = 27272443`，二进制开头是：

```
代码块
1   0010...
```

所以：

```
代码块
1   第 33 位 = 0
```

第 48 位是 `R1` 的第 16 位。

`R1` 前 16 位是：

```
代码块
1   00100111 00100111
```

第 16 位是最后一个 `1`，所以：

```
代码块
1   第 48 位 = 1
```

最终答案：

```
代码块
1   第 1 位  = 1
2   第 16 位 = 1
3   第 33 位 = 0
4   第 48 位 = 1
```

请根据DES算法原理，完成以下各题。

1）已知DES的某个S盒如下表，请根据算法原理，将表中空白位置补全。

	0	1	2	3	4	5	6	7	8	9	10	11	12	13
0	7	13	14	3	0	6	9	(1)	1	2	8	5	11	12
1	13	8	11	5	(2)	15	0	3	4	7	2	12	1	10
2	10	6	9	0	12	11	7	13	15	(3)	3	14	5	2

3	3	15	0	6	10	1	13	8	9	4	5	(4)	12	7

2) 如果有简化的DES版本，其明文输入为8比特，初始置换表IP:26314857，请给出其逆初始置换表。

3）请结合DES秘钥使用原理，查阅资料，解释什么是DES中的弱秘钥问题

答案：

1）只要看每行缺少哪个数字即可。

2）

原输入位置：1 2 3 4 5 6 7 8

出现在输出：4 1 3 5 7 2 8 6

3）在ppt DES的安全性部分

某分组密码采用 Feistel 结构

分组长度为 16 位，左右两部分各 8 位。明文分组为 $P = L_0 \| R_0$，共进行 2 轮运算，轮函数为 $F(R_{i-1}, K_i) = R_{i-1} \oplus K_i$。每轮计算公式为 $L_i = R_{i-1}$，$R_i = L_{i-1} \oplus F(R_{i-1}, K_i)$。最后输出密文为 $C = R_2 \| L_2$。已知 $L_0 = 0\text{x}3\text{A}, R_0 = 0\text{x}5\text{C}$，$K_1 = 0\text{x}0\text{F}, K_2 = 0\text{xF}0$。以下为详细计算过程。

在第 1 轮中，首先进行左半部分赋值：

$$L_1 = R_0 = 0\text{x}5\text{C}$$

接着计算轮函数：

$$F(R_0, K_1) = R_0 \oplus K_1 = 0\text{x}5\text{C} \oplus 0\text{x}0\text{F}$$

按二进制异或竖式计算：

$$\begin{aligned} 0\text{x}5\text{C} &= 01011100 \\ 0\text{x}0\text{F} &= 00001111 \\ \hline F(R_0, K_1) &= 01010011 = 0\text{x}53 \end{aligned}$$

因此，右半部分计算为：

$$R_1 = L_0 \oplus F(R_0, K_1) = 0\text{x}3\text{A} \oplus 0\text{x}53$$

按二进制异或竖式计算：

$$\begin{aligned} 0\text{x}3\text{A} &= 00111010 \\ 0\text{x}53 &= 01010011 \\ \hline R_1 &= 01101001 = 0\text{x}69 \end{aligned}$$

至此，第 1 轮计算结束，得到结果为 $L_1 = 0\text{x}5\text{C}, R_1 = 0\text{x}69$。

在第 2 轮中，首先进行左半部分赋值：

$$L_2 = R_1 = 0\text{x}69$$

接着计算轮函数：

$$F(R_1, K_2) = R_1 \oplus K_2 = 0\text{x}69 \oplus 0\text{xF}0$$

按二进制异或竖式计算：

$$\begin{array}{r} 0\text{x}69 = 01101001 \\ 0\text{xF}0 = 11110000 \\ \hline F(R_1, K_2) = 10011001 = 0\text{x}99 \end{array}$$

因此，右半部分计算为：

$$R_2 = L_1 \oplus F(R_1, K_2) = 0\text{x}5\text{C} \oplus 0\text{x}99$$

按二进制异或竖式计算：

$$\begin{array}{r} 0\text{x}5\text{C} = 01011100 \\ 0\text{x}99 = 10011001 \\ \hline R_2 = 11000101 = 0\text{xC}5 \end{array}$$

至此，第 2 轮计算结束，得到结果为 $L_2 = 0\text{x}69, R_2 = 0\text{xC}5$ 。

根据题目规定的 Feistel 结构规则，最终输出时左右两部分需要进行交换拼接：

$$C = R_2 \parallel L_2$$

将上述计算结果代入公式中：

$$C = 0\text{xC}5 \parallel 0\text{x}69$$

最终求得的 16 位十六进制密文为：

$$\mathbf{C} = 0\text{xC}569$$

D-H

二、 D-H 协议的计算

基本原理：基于求解离散对数问题的困难性

- 选择参数：参与方约定并公开两个大素数 P 和 G，其中 P 是素数，G 是模 P 的一个原根。
- 密钥生成：Alice 选择一个私密数 a 作为私钥，并计算 $A = G^a \bmod P$ ；

  Bob 选择一个私密数 b 作为私钥，并计算 $B = G^b \bmod P$ 。
- 交换信息：Alice 发送 A 给 Bob，Bob 发送 B 给 Alice。
- 计算共享密钥：Alice 计算 $S_1 = B^a \bmod P$ ，Bob 计算 $S_2 = A^b \bmod P$ ，共享密钥

$$S = S_1 = S_2$$

☆练习 1

已知 $P = 71, G = 7, A$ 的私钥为 $X_A = 5, B$ 的私钥 $X_B = 12$.

求 A、B 的公钥以及共享密钥.

答案：51、4、30

RSA

一、 RSA 的计算

基本原理：RSA 算法基于大数分解的数学问题。可用于加密和数字签名

01 密钥生成：

- 选择两个大质数 p 和 q，**计算 n = pq，φ(n) = (p-1)(q-1);**
- 选择一个整数 e , $(1 < e < \varphi(n))$ 且 e 与φ(n)互质.
- 根据等式：$(de) \bmod \varphi(n) = 1$ 计算 d .
- **公钥：(e,n) ，私钥：(d,n) . (只写 e 或 d 都是正确的).**

02 加密：密文 C = M^e mod n，消息 M 是一个小于 n 的整数;

03 解密：消息 M = C^d mod n。

☆练习 1

若 $p = 3, q = 11, e = 7, M = 5$ ，求加解密过程.

解答： $n = pq = 33, \varphi(n) = (p-1)(q-1) = 20$

由于 $e = 7$, 则公钥 $pk = 7$

根据 $7d \bmod 20 = 1$, 计算得到 $d = 3$, 因此私钥 $sk = 3$

密文：$C = 5^7 \bmod 33 = 14,$

解密：$M' = 14^3 \bmod 33 = 5$

☆练习 2

在使用 *RSA* 的公钥体制中，已截获发给某用户的密文 $C = 10$ ，该用户的公钥 $e = 5$ ， $n = 35$ ，那么明文 M 是多少?

解答： 倘若直接根据 $M^5 \bmod 35 = 10$, 额，似乎不太好计算，

注意到 $n = pq = 35 = 5 \times 7$, 不妨假设 $p = 5, q = 9$ ，因此 $\varphi(n) = 4 \times 6 = 24$

因此 $5d \bmod 24 = 1$, 则 $d = 5$

因此 $M = C^d \bmod 35 = 10^5 \bmod 35 = 5$

计算技巧

Tips1：求高阶幂运算， $ab \bmod n = ((a \bmod n)(b \bmod n)) \bmod n$**，核心思想：递归拆分**

Q：求$3^{78} \bmod 7 = ?$

A：将3^{78}拆分成尽可能小的两部分进行计算(等分),按①–⑧顺序进行逐一计算

①$3^{78} \bmod 7 = (3^{39} \cdot 3^{39}) \bmod 7$⑧$= (6 \cdot 6) \bmod 7 = 1$

②$3^{39} \bmod 7 = (3^{19} \cdot 3^{19} \cdot 3) \bmod 7$⑦$= (3 \cdot 3 \cdot 3) \bmod 7 = 6$

③$3^{19} \bmod 7 = (3^{9} \cdot 3^{9} \cdot 3) \bmod 7$⑥$= (6 \cdot 6 \cdot 6) \bmod 7 = 3$

④$3^{9} \bmod 7 = (3^{4} \cdot 3^{4} \cdot 3) \bmod 7$⑤$= (4 \cdot 4 \cdot 3) \bmod 7 = 6$

按照这个思路，以上5^7是不是就相对更好计算了！

选取两个不同的质数：p = 7, q = 19，请使用RSA算法完成消息的加密。请根据上述信息回答以下问题，并写出计算过程。

1）计算出 n 的值是多少?

2）计算出 φ(n) 的值是多少?

3）如果选择e=11，请计算出私钥 d 的值。

4）使用公钥加密消息 M = 3，请计算密文的值。

对于RSA算法若截获e=5，n=35的用户密文C=10，请问明文M是多少？从这个题的求解，说明了什么?

密码学基础2

密码学基本数学知识

整数分解

模运算

模 n 下 a 循环群 G 定义为 $\{a^0 = e, a \pmod n, a^2 \pmod n, \dots\}$ 称为由 a 生成的循环群，a 为 G 的生成元。

- 求模 19 下 7 的循环群。
- 若模 19 下 3 的循环群为 $\mathbb{Z}_{19}^*$（即模 19 的正整数乘法群），求该循环群的全部元素，并指出该群的阶以及所有的生成元。

答案：

根据题目定义，模 n 下 a 的循环群是由 a 的各乘方对 n 取模后得到的元素集合，形式为 $G = \{a^0 \equiv e, a^1 \pmod n, a^2 \pmod n, \dots\}$。这里模数 $n = 19$，单位元 $e = 1$。

对于第 1 问，生成元 $a=7$。通过依次计算 7 的各次幂模 19 的余数，直到结果重新循环回到 1 为止：

$7^0 \equiv 1 \pmod{19}$

$7^1 \equiv 7 \pmod{19}$

$7^2 = 49 \equiv 11 \pmod{19}$

$7^3 \equiv 11 \times 7 = 77 \equiv 1 \pmod{19}$

可以看到当指数为 3 时，结果重新回到了 1 ，说明该循环群的周期为 3 。因此，模 19 下 7 的循环群为：

$G = \{1, 7, 11\}$

对于第 2 问，生成元 $a=3$。我们依次计算 3 的各次幂模 19 的余数：

$3^0 \equiv 1, \quad 3^1 \equiv 3, \quad 3^2 \equiv 9, \quad 3^3 \equiv 8, \quad 3^4 \equiv 5 \pmod{19}$

$3^5 \equiv 15, \quad 3^6 \equiv 7, \quad 3^7 \equiv 2, \quad 3^8 \equiv 6, \quad 3^9 \equiv 18 \pmod{19}$

$3^{10} \equiv 16, \quad 3^{11} \equiv 10, \quad 3^{12} \equiv 11, \quad 3^{13} \equiv 14, \quad 3^{14} \equiv 4 \pmod{19}$

$3^{15} \equiv 12, \quad 3^{16} \equiv 17, \quad 3^{17} \equiv 13, \quad 3^{18} \equiv 1 \pmod{19}$

此时刚好遍历了 1 到 18 的所有正整数，因此模 19 下 3 的循环群全部元素为 $\{1, 2, 3, 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18\}$。该群的阶（元素个数）为 18。

根据循环群的性质，若 g 是阶为 m 的循环群的生成元，则 g^k 也是生成元的充要条件是 $\gcd(k, m) = 1$。这里群的阶 $m = 18$，在 1 到 18 之间与 18 互素的指数 k 有：
$\phi(18) = \phi(2 \times 3^2) = 18 \times (1 - \frac{1}{2}) \times (1 - \frac{1}{3}) = 6$ 个，具体的 k 值为 $\{1, 5, 7, 11, 13, 17\}$。

将这些指数对应的元素 $3^k \pmod{19}$ 映射出来，即可得到该群的所有生成元（即模 19 的所有阶为 18 的本原根）：

$3^1 \equiv 3, \quad 3^5 \equiv 15, \quad 3^7 \equiv 2, \quad 3^{11} \equiv 10, \quad 3^{13} \equiv 14, \quad 3^{17} \equiv 13$

所以，该循环群的所有生成元为 $\{2, 3, 10, 13, 14, 15\}$。

有限域

欧几里得算法

使用欧几里得算法，求整数 360、210 和 126 的最大公约数（GCD），要求写出完整的分步计算过程。

第一步：求 gcd (360,210)用欧几里得算法：

360=210×1+150

10=150×1+60

150=60×2+30

60=30×2+0

当余数为 0 时，最后一个非零余数就是最大公约数。

所以：gcd (360,210)=30

第二步：求 gcd (30,126)继续用欧几里得算法：

126=30×4+6

30=6×5+0

所以：gcd (30,126)=6

中国剩余定理

用中国剩余定理求解满足以下条件的最小正整数 x：

1. x 除以 **4**，余 **1**；
2. x 除以 **9**，余 **4**；
3. x 除以 **11**，余 **5**。

答案：

因为 $4, 9, 11$ 两两互素，所以可以用中国剩余定理。先算总模数：

$M = 4 \times 9 \times 11 = 396$

分别计算各部分的 M_i：

$M_1 = \frac{396}{4} = 99$

$M_2 = \frac{396}{9} = 44$

$M_3 = \frac{396}{11} = 36$

接下来找每个 M_i 在对应模数下的数论倒数（逆元）。

对第一个方程 $99e_1 \equiv 1 \pmod 4$：

因为 $99 \equiv 3 \pmod 4$，所以 $3e_1 \equiv 1 \pmod 4$，可得：

$e_1 = 3$

对第二个方程 $44e_2 \equiv 1 \pmod 9$：

因为 $44 \equiv 8 \pmod 9$，所以 $8e_2 \equiv 1 \pmod 9$，可得：

$e_2 = 8$

对第三个方程 $36e_3 \equiv 1 \pmod{11}$：

因为 $36 \equiv 3 \pmod{11}$，所以 $3e_3 \equiv 1 \pmod{11}$，可得：

$e_3 = 4$

根据中国剩余定理的组合公式 $x \equiv a_1M_1e_1 + a_2M_2e_2 + a_3M_3e_3 \pmod M$，将余数 $a_1 = 1, a_2 = 4, a_3 = 5$ 及上述结果代入：

$x \equiv 1 \times 99 \times 3 + 4 \times 44 \times 8 + 5 \times 36 \times 4 \pmod{396}$

$x \equiv 297 + 1408 + 720 \pmod{396}$

$x \equiv 2425 \pmod{396}$

再把 2425 对 396 取模：

$$2425 - 396 \times 6 = 2425 - 2376 = 49$$

所以得到同余式：

$$x \equiv 49 \pmod{396}$$

该同余方程组的最小正整数解为：

$$x = 49$$

最后代入原方程组进行验证：

$$49 \equiv 1 \pmod{4}$$

$$49 \equiv 4 \pmod{9}$$

$$49 \equiv 5 \pmod{11}$$

圆锥曲线

1. **在实数域上的椭圆曲线 $E: y^2 = x^3 - 36x$ 中，已知点 $P = (-3, 9)$ 和 $Q = (-2, 8)$，计算 P+Q和 2P**

已知椭圆曲线方程的参数 $A = -36, B = 0$。当椭圆曲线上两个不同的点相加时，先求过 P, Q 两点的直线斜率 k：

$$k = \frac{y_Q - y_P}{x_Q - x_P}$$

将 $P(-3, 9)$ 和 $Q(-2, 8)$ 代入该斜率公式中：

$$k = \frac{8 - 9}{-2 - (-3)} = \frac{-1}{1} = -1$$

接着根据加法公式计算交点横坐标 $x_{P+Q} = k^2 - x_P - x_Q$：

$$x_{P+Q} = (-1)^2 - (-3) - (-2) = 1 + 3 + 2 = 6$$

随后根据公式 $y_{P+Q} = k(x_P - x_{P+Q}) - y_P$ 计算交点纵坐标：

$$y_{P+Q} = (-1) \times (-3 - 6) - 9 = (-1) \times (-9) - 9 = 9 - 9 = 0$$

由此得到第一步的计算结果：

$$P + Q = (6, 0)$$

计算 $2P$ 即点 P 自身的相加（$P + P$）。此时直线为曲线在 P 点的切线，切线斜率 k 的计算公式为：

$$k = \frac{3x_P^2 + A}{2y_P}$$

将 $A = -36$ 及 $P(-3, 9)$ 代入切线斜率公式中：

$$k = \frac{3(-3)^2 - 36}{2 \times 9} = \frac{27 - 36}{18} = \frac{-9}{18} = -\frac{1}{2}$$

接着根据倍点公式计算横坐标 $x_{2P} = k^2 - 2x_P$：

$$x_{2P} = \left(-\frac{1}{2}\right)^2 - 2(-3) = \frac{1}{4} + 6 = 6.25$$

随后根据公式 $y_{2P} = k(x_P - x_{2P}) - y_P$ 计算纵坐标：

$$y_{2P} = -\frac{1}{2} \times (-3 - 6.25) - 9 = -\frac{1}{2} \times (-9.25) - 9 = 4.625 - 9 = -4.375$$

由此得到第二步的计算结果：

$$2P = (6.25, -4.375)$$

2. **已知有限域椭圆曲线 $E_{23}(1,1) : y^2 \equiv x^3 + x + 1 \pmod{23}$，其中参数 $a = 1$。曲线上已知两点 $P = (3, 10)$，$Q = (9, 7)$。计算-P，P+Q，2P**

首先计算 $-P$。在有限域椭圆曲线中，点 $P = (x, y)$ 的相反点为 $-P = (x, -y \pmod{p})$。

将 $P(3, 10)$ 代入可得：

$$-P = (3, -10 \pmod{23})$$

因为 $-10 \equiv 13 \pmod{23}$，所以：

$$-P = (3, 13)$$

接着计算 $P + Q$。因为 $P \neq Q$，过两点的直线斜率 k 的计算公式为：

$$k = \frac{y_Q - y_P}{x_Q - x_P} \pmod{23}$$

代入已知点坐标：

$$k = \frac{7 - 10}{9 - 3} = \frac{-3}{6} \pmod{23}$$

在有限域中除法需要转换为乘以分母的乘法逆元。因为 $6 \times 4 = 24 \equiv 1 \pmod{23}$，所以 6 在模 23 下的逆元为 $6^{-1} \equiv 4 \pmod{23}$。（6^−1(mod23)的值就是6x≡1(mod23)里面x的值）

将其代入斜率计算：

$$k \equiv -3 \times 4 = -12 \equiv 11 \pmod{23}$$

根据加法公式计算横坐标 $x_{P+Q} = k^2 - x_P - x_Q \pmod{23}$：

$$x_{P+Q} = 11^2 - 3 - 9 = 121 - 12 = 109$$

将结果对 23 取模：$109 \equiv 17 \pmod{23}$。

根据公式 $y_{P+Q} = k(x_P - x_{P+Q}) - y_P \pmod{23}$ 计算纵坐标：

$$y_{P+Q} = 11 \times (3 - 17) - 10 = 11 \times (-14) - 10 = -154 - 10 = -164$$

将结果对 23 取模：$-164 \equiv 20 \pmod{23}$。所以：

$$P + Q = (17, 20)$$

最后计算 $2P$（倍点运算）。对于相同的点相加，使用切线斜率公式：

$$k = \frac{3x_P^2 + a}{2y_P} \pmod{23}$$

代入参数 $a = 1$ 与 $P(3, 10)$ 的坐标：

$$k = \frac{3 \times 3^2 + 1}{2 \times 10} = \frac{27 + 1}{20} = \frac{28}{20} \pmod{23}$$

分子化简为 $28 \equiv 5 \pmod{23}$，斜率式变为 $k \equiv 5 \times 20^{-1} \pmod{23}$。因为 $20 \times 15 = 300 \equiv 1 \pmod{23}$，所以分母的逆元为 $20^{-1} \equiv 15 \pmod{23}$。计算出斜率：

$$k \equiv 5 \times 15 = 75 \equiv 6 \pmod{23}$$

根据倍点公式计算横坐标 $x_{2P} = k^2 - 2x_P \pmod{23}$：

$$x_{2P} = 6^2 - 2 \times 3 = 36 - 6 = 30$$

将结果对 23 取模：$30 \equiv 7 \pmod{23}$。

根据公式 $y_{2P} = k(x_P - x_{2P}) - y_P \pmod{23}$ 计算纵坐标：

$$y_{2P} = 6 \times (3 - 7) - 10 = 6 \times (-4) - 10 = -24 - 10 = -34$$

将结果对 23 取模：$-34 \equiv 12 \pmod{23}$。所以：

$$2P = (7, 12)$$

身份认证

零知识证明

2. 有两颗形状、大小完全一样的球：一颗红球、一颗绿球，X 是红绿色盲，Y 能够向 X 证明这两颗球是一红一绿吗？【零知识证明】

参考解答：

- X 左手拿着红球，右手拿着绿球，并在背后不让 Y 看到，进行交换(或者不交换)两只球；
- Y 能够根据颜色精准判断 X 是否进行了交换；
- 执行上述操作 N 次后，Y 都能精确判断，即能在 X 是色盲的情况下，Y 仍能够向 X 证明能这两颗球是一红一绿。

2. 如何向色盲患者证明这个世界是有颜色的?

零知识证明 Zero-Knowledge Proof

也可以归到：**交互式证明 / 最小泄露证明 / 身份认证协议**

PPT 里讲的是：证明者 P 要向验证者 V 证明自己知道某个事实，但不能让 V 得到这个事实本身以外的额外信息。

答案：

设有两张纸：

- 纸 A：红色
- 纸 B：绿色

两张纸除了颜色不同，形状、大小、材质完全一样。

色盲患者 X 无法区分红绿，证明者 Y可以区分。

操作如下：

X 先记住两张纸的位置，比如左边是 A，右边是 B。

X 把两张纸放到背后，随机选择：

- 交换两张纸；
- 或者不交换。

X 再把两张纸拿出来，让 Y 判断：刚才是否交换。

如果 Y 真的能区分颜色，就能准确判断是否交换。

重复多次，如果 Y 每次都答对，X 就可以相信这两张纸确实存在可区分的颜色差异。

综合题

你可以把这13章看成一套完整的“网络安全解决问题流程”，而不是13块分散知识：

> **先明确要保护什么 → 再用密码技术保护数据 → 管好密钥和身份 → 分析攻击 → 部署防御 → 最后应用到实际系统。**

一、 核心主线

第1章：网络空间安全概述——明确“保护什么”

这一章是总纲，核心不是记法律名称，而是建立安全目标：

- **机密性**：信息不能被未授权者看到
- **完整性**：信息不能被篡改
- **真实性**：确认用户、设备和消息来源真实
- **不可否认性**：发送者事后不能抵赖
- **可用性**：系统在需要时能够正常使用

综合题第一步通常就是判断题目中哪些安全目标受到了威胁。

例如：

- 通信被偷听 → 机密性
- 文件被修改 → 完整性
- 攻击者冒充用户 → 真实性
- 发送者否认发过文件 → 不可否认性
- 网站被DDoS打瘫 → 可用性

第2、3章：密码学基础——解决“数据怎么保护”

这两章是密码技术的基础。

第2章偏重：

- 古典密码
- 对称密码
- 公钥密码
- DES、AES、RSA、ECC、Diffie-Hellman

第3章偏重：

- 密码体制分类
- 密码攻击类型
- 数学基础
- 各种现代密码算法

它们主要解决两个问题：

1. **加密数据，保证机密性**
2. **交换或协商密钥**

最常见关系是：

- AES等对称加密：速度快，适合加密大量数据
- RSA、ECC等公钥密码：速度较慢，适合交换密钥、签名和认证
- Diffie-Hellman：协商共享密钥

实际系统一般不是只用一种算法，而是：

> 公钥技术安全交换密钥，对称密码加密大量数据。

第4章：消息鉴别——解决“数据有没有被改”

加密只能让攻击者看不懂，但不能完全证明数据没有被修改。

本章核心：

- Hash
- 消息摘要
- MAC
- MD5、SHA、SM3

它们解决：

- 消息完整性
- 消息来源鉴别

需要特别区分：

- **Hash**：只能发现内容是否变化，不能单独证明是谁发送的
- **MAC**：使用共享密钥，能够验证完整性和消息来源
- **加密**：主要保证机密性

第5章：数字签名——解决“谁发的、能否抵赖”

数字签名建立在：

- 公钥密码
- Hash
- 私钥安全

之上。

过程是：

> 发送者对消息求Hash → 用私钥签名摘要 → 接收者用发送者公钥验证。

它提供：

- 完整性
- 身份认证
- 不可否认性

所以第4、5章可以串成：

> **Hash检查是否改变 → MAC验证共享密钥双方的消息 → 数字签名实现公开验证和防抵赖。**

上传资料中“机密文件传送且不能抵赖”“彩票防伪”“数字签名流程”等题目，都是第2—5章的综合使用。

第6章：信息隐藏——解决“怎样隐藏秘密的存在”

密码学是：

> 别人知道你传了密文，但看不懂内容。

信息隐藏是：

> 别人尽量不知道你传了秘密信息。

核心包括：

- 隐写术
- 数字水印
- LSB
- DCT水印
- 卡方分析、RS分析

主要应用：

- 秘密通信
- 版权保护
- 内容认证
- 信息追踪

它和加密可以组合：

> 先对秘密信息加密，再把密文隐藏到图像中。

第7章：密钥管理——解决“密钥怎么安全使用”

密码算法再强，如果密钥泄露，也没有意义。

核心包括：

- 密钥生成
- 密钥分配
- 密钥协商
- 密钥存储
- 密钥更新
- 门限秘密共享

它连接了几乎全部密码章节：

- 对称加密需要共享密钥
- 数字签名需要保护私钥
- 身份认证需要认证密钥
- 公钥体系需要证明公钥属于谁

所以密码安全不只是“选算法”，还要回答：

> 密钥从哪里来、怎么传、谁能用、怎么保存、泄露后怎么办。

第8章：密码学基础3——解决新场景中的密码问题

这一章是密码技术的进一步发展：

- 身份基密码：减少证书管理问题
- 属性基密码：按属性进行细粒度访问控制
- 同态密码：在密文上直接计算
- 抗量子密码：应对量子计算威胁
- 轻量级密码：适合物联网、传感器等资源受限设备

它与前面章节的关系是：

> 第2、3章讲传统密码；第8章讲传统密码在云计算、物联网、隐私计算和量子时代如何扩展。

第9章：网络攻击——理解“攻击者怎么打”

这一章从防守视角转向攻击视角。

核心攻击包括：

- 扫描
- 网络监听
- ARP欺骗
- DoS/DDoS
- 缓冲区溢出
- SQL注入
- 病毒与木马

不同攻击破坏不同目标：

- 网络监听 → 机密性
- ARP欺骗 → 通信真实性、机密性、完整性
- SQL注入 → 数据库完整性和机密性
- 缓冲区溢出 → 系统控制权
- DDoS → 可用性
- 木马 → 数据和系统安全

综合题中，先判断威胁类型，再选择防御措施。

第10章：防火墙——负责“拦截和隔离”

防火墙的核心作用是访问控制：

> 根据规则决定哪些网络流量允许通过，哪些必须阻止。

主要技术：

- 包过滤
- 代理
- 状态检测
- NAT
- DMZ

它适合：

- 限制非法IP和端口
- 隔离内外网
- 保护服务器
- 划分不同安全区域

但是它不能发现所有攻击，尤其是：

- 已允许端口中的攻击
- 内部人员攻击

- 加密流量内部的恶意内容
- 新型或应用层攻击

因此需要第11章。

第11章：入侵检测——负责“发现异常和攻击”

入侵检测系统IDS的核心是：

> 收集信息 → 分析行为 → 发现攻击 → 告警或处理。

按数据来源：

- HIDS：监控主机日志、文件、进程
- NIDS：监控网络流量

按检测方法：

- 误用检测：匹配已知攻击特征
- 异常检测：发现偏离正常行为的活动

防火墙和IDS的关系是：

> **防火墙像门卫，决定能不能进；IDS像监控，判断进来之后有没有异常。**

上传资料中“只部署防火墙，为什么还需要入侵检测”就是典型综合题。

第12章：身份认证——解决“你是谁”

身份认证用于确认用户或设备身份。

认证依据包括：

- 知道的：密码、口令
- 拥有的：手机、令牌、智能卡
- 自身特征：指纹、人脸、虹膜
- 行为特征：签名、语音、步态

技术发展顺序：

> 静态口令 → 动态口令 → 挑战应答 → 密码协议 → 零知识证明 → 生物特征认证

它与前面章节联系紧密：

- Hash用于存储口令摘要
- 公钥密码用于认证
- 数字签名证明私钥持有者身份
- 密钥管理保护认证密钥
- Kerberos依赖可信第三方和对称密钥

第13章：区块链——前面技术的综合应用

区块链不是单独的一种密码算法，而是多种技术结合：

- Hash：连接区块、构建Merkle树
- 数字签名：验证交易发起者
- 公私钥：管理交易权限
- 网络通信：传播交易和区块
- 共识机制：让分布式节点达成一致

所以可以理解为：

> **Hash保证修改可发现，数字签名保证交易授权，共识机制保证分布式账本一致。**

二、把13章串成一条完整链条

最重要的主线是：

> **第1章提出安全目标**
> **→ 第2—5章用密码、Hash、MAC、签名保护数据**
> **→ 第6章隐藏信息和保护版权**
> **→ 第7章管理密码系统中的密钥**
> **→ 第8章解决云计算、物联网和量子时代的新问题**
> **→ 第9章分析攻击者如何攻击**
> **→ 第10、11章进行访问控制和攻击检测**
> **→ 第12章确认用户和设备身份**
> **→ 第13章综合应用这些技术。**

三、综合题为什么会迷茫

因为综合题不是问“某章有什么”，而是给你一个场景，让你完成：

> **发现风险 → 判断安全目标 → 选择技术 → 解释作用。**

例如题目：

> 政府部门要通过网络传输机密文件，如何保证安全？

不要直接堆技术名词，而要逐项分析。

1.1 文件可能被偷看

威胁：网络监听。

目标：机密性。

措施：使用AES加密文件，利用TLS、VPN或安全文件传输协议保护传输链路。

1.2 文件可能被修改

目标：完整性。

措施：使用Hash、MAC或数字签名验证内容。

1.3 攻击者可能冒充发送方

目标：真实性。

措施：数字证书、数字签名、双向身份认证。

1.4 发送方可能抵赖

目标：不可否认性。

措施：使用发送方私钥进行数字签名。

1.5 密钥可能泄露

措施：密钥协商、安全存储、定期更新和撤销。

1.6 系统可能遭到攻击

措施：防火墙、IDS、漏洞修补、恶意软件防护和日志审计。

这样答案就自然串起了：

- 第2—3章加密
- 第4章完整性
- 第5章签名
- 第7章密钥管理
- 第10章防火墙
- 第11章入侵检测
- 第12章身份认证

四、综合题固定答题步骤

以后看到任何场景题，先写这五步。

第一步：识别对象

题目保护的是：

- 数据
- 网络
- 主机
- 用户账户
- 服务
- 数字内容

第二步：识别威胁

常见威胁：

- 窃听

- 篡改
- 冒充
- 重放
- 越权
- 恶意软件
- 漏洞攻击
- DoS
- 内部人员泄露

第三步：对应安全目标

风险	安全目标
被窃听	机密性
被修改	完整性
被冒充	真实性
事后否认	不可否认性
无法使用	可用性
非法访问	访问控制

第四步：选择技术

- 机密性 → 加密、TLS、VPN
- 完整性 → Hash、MAC、数字签名
- 真实性 → 身份认证、证书、签名
- 不可否认性 → 数字签名
- 非法访问 → 访问控制、防火墙
- 异常攻击 → IDS
- 软件漏洞 → 补丁、输入校验、安全编程
- 数据丢失 → 备份恢复
- 密钥问题 → 密钥管理

第五步：补充管理措施

综合题最后通常还可以补：

- 权限最小化
- 日志审计
- 定期补丁
- 数据备份
- 安全培训

- 应急响应
- 物理安全

五、最实用的综合题答案框架

可以直接套：

> 该系统主要面临窃听、篡改、身份冒充、越权访问、漏洞攻击和拒绝服务等风险。首先，应使用加密算法和TLS、VPN等安全协议保障通信机密性；其次，使用Hash、MAC或数字签名保证数据完整性和来源真实性，其中数字签名还可实现不可否认性；再次，采用强口令、多因素认证、数字证书和权限控制防止非法用户访问。网络边界部署防火墙进行流量过滤和区域隔离，同时部署入侵检测系统监控异常行为。系统还应及时修补漏洞、安装恶意软件防护、保护和定期更新密钥，并建立日志审计、数据备份、安全培训和应急响应机制。

这段框架基本能覆盖你资料中的：

- Web服务器安全
- 网络安全体系建设
- 政府文件传输
- 跨国公司通信
- ATM安全
- 无人机安全通信
- 初创企业安全建设

但考试时要根据场景删掉无关内容，重点说明每项措施针对什么风险，不能只是罗列名词。综合题资料中的大多数答案，本质上都在重复这条“威胁—目标—措施”的逻辑。

一、这些综合题看起来很多，实际主要只有几种类型

根据你给的《综合题》和各章 PPT，题目虽然会更换场景，如 WEB 服务器、企业网络、无人机、公共 Wi-Fi、社交平台、商品防伪等，但本质上主要考下面 **5 类**。

1. 安全体系建设型

常见问法：

- 如何保障 WEB 服务器安全?
- 如何构建单位网络安全体系?
- 小型企业如何建立安全基础设施?
- 针对某信息系统提出安全防护措施。

这类题的核心不是只写一种技术，而是考你能不能形成**纵深防御体系**。综合题中的企业网络安全答案通常同时包括物理安全、防火墙、IDS、补丁、杀毒、备份、加密、访问控制、审计、应急和人员培

训。

作答顺序

建议按照：

> 物理安全 → 网络边界 → 主机系统 → 应用与数据 → 用户权限 → 检测审计 → 管理与应急

通用模板

1. **物理安全**：保护机房、服务器和网络设备，防止断电、火灾、盗窃和非法接触。
2. **网络边界安全**：部署防火墙、划分安全区域或 DMZ，配置访问控制规则，阻断非法访问。
3. **入侵检测**：部署 IDS/IPS，实时发现扫描、攻击和异常流量，与防火墙形成联动。
4. **主机与应用安全**：关闭无关端口和服务，及时安装补丁，修复系统与应用漏洞。
5. **身份认证与访问控制**：采用强口令、多因素认证和最小权限原则，防止越权访问。
6. **通信与数据保护**：使用 SSL/TLS、IPSec 等加密通信，对敏感数据加密存储。
7. **恶意代码防护**：部署杀毒软件、安全网关并及时更新病毒库。
8. **备份与恢复**：定期备份重要数据，进行异地或离线备份，并测试恢复能力。
9. **日志与审计**：记录登录、访问、修改和异常操作，定期审核并追踪责任。
10. **安全管理**：建立安全制度、人员培训、应急响应和定期风险评估机制。

防火墙负责在不同安全区域边界执行访问控制、隔离网络、记录流量，但存在“防外不防内”、不能防止绕过防火墙的攻击等局限，因此通常需要配合 IDS、主机安全和管理制度。

---

2. 威胁分析与防范型

常见问法：

- 分析信息系统面临的安全威胁。
- 网络为什么不安全？如何防范？
- 列举社交平台、大语言模型、公共 Wi-Fi 的安全隐患并给出建议。
- 分析某种攻击并提出防御措施。

这类题最好使用：

> **问题或威胁 → 造成的后果 → 对应防范措施**

不要只罗列“病毒、黑客、泄露”，而要写出对应关系。

威胁分析的常用角度

角度一：攻击来源

- 外部攻击者
- 内部人员
- 合作方或第三方

- 用户误操作
- 自然环境和设备故障

角度二：攻击方式

- 窃听、嗅探：破坏机密性
- 篡改、伪造：破坏完整性和真实性
- 冒充、身份欺骗：破坏认证性
- 重放攻击：重复发送合法报文
- 拒绝服务、无线干扰：破坏可用性
- 恶意代码、木马、病毒
- 漏洞利用、缓冲区溢出、SQL 注入
- 越权访问、权限滥用
- 数据泄露和隐私侵犯

网络攻击 PPT 将攻击分为主动攻击和被动攻击：被动攻击主要收集信息，如监听；主动攻击包括拒绝服务、篡改、资源滥用和欺骗等。

角度三：系统层次

- 物理层：设备破坏、断电、火灾
- 网络层：监听、欺骗、路由攻击、拒绝服务
- 主机层：系统漏洞、弱口令、恶意软件
- 应用层：SQL 注入、越权、输入验证缺陷
- 数据层：泄露、篡改、丢失
- 管理层：制度不完善、权限混乱、员工意识不足

通用答题格式

> 第一，存在……风险，攻击者可能通过……造成……。对此，应采用……措施。
> 第二，存在……风险，可能导致……。对此，应……。
> 第三，存在……风险，应通过……进行防范。

例子

账号被盗问题：

- 风险：用户采用弱口令，或者同一口令在多个平台重复使用，攻击者可能进行字典攻击或撞库。
- 后果：造成身份冒用、隐私泄露和资金损失。
- 措施：采用复杂且唯一的口令、启用多因素认证、限制登录尝试、设置异常登录告警。

这样的写法比单写“使用强密码”更完整。

---

3. 安全通信协议设计型

常见问法：

- 为无人机设计安全通信协议。
- 为物联网、车联网或移动设备设计安全通信机制。
- 如何保障双方通信安全？
- 如何在不可信网络中传输敏感数据？

这类题看起来最难，但实际上最有固定模板。

密码学 PPT 给出的安全目标主要包括：**保密性、完整性、可用性、认证性和不可否认性**。

协议题固定思路

> 先认证身份 → 再协商密钥 → 加密数据 → 校验完整性 → 防止重放 → 管理密钥 → 保障可用性 → 异常处置

标准模板

1. **身份认证**
   为通信实体配置唯一身份、公私钥或数字证书，通信前进行双向认证，防止攻击者冒充合法节点。
2. **密钥协商**
   使用 Diffie-Hellman、ECDH 等方式协商临时会话密钥，避免长期使用同一个固定密钥。
3. **通信加密**
   使用 AES、SM4 等对称加密算法保护大量业务数据，防止监听和泄露。
4. **完整性与消息认证**
   对消息附加 MAC/HMAC，接收方重新计算并比较，检测内容是否被篡改，同时验证消息是否来自掌握共享密钥的合法通信方。MAC 可以保障消息完整性和来源真实性，但本身不提供保密性。
5. **数字签名**
   对关键命令、合同、交易记录等使用数字签名，保证消息来源真实、内容完整，并提供抗抵赖性。数字签名尤其适合收发双方可能存在利益冲突的场景。
6. **防重放攻击**
   在报文中加入随机数、时间戳、序列号、会话编号或任务编号，拒绝重复和过期报文。
7. **访问控制**
   按角色分配权限，普通节点只能访问完成任务所需的资源，关键命令只能由授权主体发送。
8. **密钥管理**
   对密钥进行安全生成、存储、分配、更新、撤销和销毁；设备丢失或失陷后立即撤销其证书和密钥。密钥管理应覆盖密钥从产生到最终销毁的整个生命周期。
9. **可用性保障**
   采用冗余节点、备用链路、多路径传输、限流和抗干扰技术，抵御拒绝服务攻击和通信中断。
10. **异常与失联处理**
    发生认证失败、报文异常、设备失陷或通信中断时，立即告警、隔离节点、切换备用链路或进入安全模式。

无人机综合题的参考答案基本就是按照身份认证、密钥协商、加密、MAC、数字签名、防重放、路由安全、密钥管理、抗干扰、失联保护和访问控制展开。

一句话记忆

> **认、协、密、整、签、防重放、管密钥、保可用。**

---

4. 安全机制或方案设计型

常见问法：

- 利用加密技术设计商品真伪查询机制。
- 设计电子交易、身份认证、文件保护方案。
- 用数字签名或水印解决某个实际问题。
- 为某场景选择合适的密码技术。

这类题不要只写算法名称，要写清楚：

> 谁生成什么 → 使用什么密钥处理 → 发送或保存什么 → 接收方如何验证 → 如何防攻击

五步设计模板

1. **参与实体**：明确发送者、接收者、服务器、认证机构或可信第三方。
2. **初始化**：生成身份、随机数、密钥、证书或水印。
3. **发送方处理**：加密、计算摘要、生成 MAC、签名或嵌入水印。
4. **接收方验证**：解密、重新计算摘要或 MAC、验证签名、检测水印。
5. **安全分析**：说明方案实现了哪些安全目标，还要防止哪些攻击。

不同需求对应的技术

需求	应选技术
防止别人看懂内容	加密
证明数据没有被修改	Hash、MAC、数字签名
验证消息来自共享密钥持有者	MAC/HMAC
验证公开身份并防止抵赖	数字签名
防止重放	随机数、时间戳、序列号
解决公钥真实性	数字证书、CA
保护数字作品版权	数字水印
隐藏秘密通信存在	信息隐藏、隐写
控制不同用户访问资源	身份认证与访问控制

数字水印适合版权保护，因为水印可永久嵌入宿主数据，并强调可证明性、鲁棒性、透明性和安全性。

常见错误

- 说“用公钥加密保证数字签名”——加密和签名的目的不同。
- 说“Hash 可以验证发送者身份”——普通 Hash 没有密钥，攻击者修改消息后也能重新计算。
- 说“MAC 可以防抵赖”——MAC 的密钥由双方共享，接收方也能生成 MAC，所以通常不能向第三方证明一定是发送方生成的。
- 只说“使用 AES、RSA”，但不解释谁用谁的密钥、处理什么数据。
- 忘记防止重放和密钥泄露。

针对该场景，首先明确需要保护的对象为【业务数据、用户身份、文件、交易信息或数字作品】，系统可能面临窃听、篡改、伪造、冒充、重放、抵赖和密钥泄露等威胁。因此，应从保密性、完整性、认证性、不可否认性和可用性等方面设计安全机制。

（1）明确参与实体。系统中的参与实体包括信息发送方、信息接收方、安全服务器以及必要时负责签发证书的认证机构。每个实体应具有唯一身份，并根据其身份和角色分配相应权限。

（2）完成系统初始化。系统为各参与实体生成身份标识、公私钥对、数字证书或共享密钥。公钥和证书可以公开，私钥和共享密钥必须安全保存。系统还应准备随机数生成器、时间同步机制以及安全的密码算法。

（3）进行身份认证。通信或业务开始前，双方应通过口令、数字证书、智能卡或多因素认证确认对方身份。重要系统可以采用双向认证，既验证用户身份，也验证服务器身份，防止攻击者冒充合法通信方。

（4）生成会话密钥。对于需要传输大量数据的场景，发送方随机生成一次性会话密钥，或由通信双方通过安全密钥协商协议建立会话密钥。会话密钥只在本次通信中使用，降低长期密钥泄露造成的风险。

（5）保护消息的保密性。发送方使用 AES、SM4 等对称加密算法和会话密钥对业务数据进行加密。若需要传递会话密钥，可以使用接收方的公钥对会话密钥加密，使只有持有对应私钥的接收方能够获得会话密钥并解密数据。

（6）保护消息的完整性和来源真实性。发送方可以对消息计算 MAC 或 HMAC，并将消息与鉴别码一同发送。接收方收到消息后，使用相同密钥重新计算 MAC 并进行比较。如果两者一致，则说明消息在传输过程中未被篡改，并且消息来自掌握共享密钥的合法通信方。

（7）对重要消息进行数字签名。对于电子合同、交易命令、重要文件等需要防止抵赖的内容，发送方先对消息计算 Hash 摘要，再使用自己的私钥对摘要进行数字签名。接收方使用发送方的公钥验证签名，并重新计算消息摘要进行比较，从而确认发送方身份、消息完整性以及发送方不能抵赖。

（8）防止重放攻击。发送方在消息中加入时间戳、随机数、序列号或唯一业务编号。接收方检查时间是否有效、序列号是否连续、随机数或业务编号是否已经使用，并拒绝重复或过期的消息。

（9）实施访问控制。系统根据用户身份、角色或属性分配权限，实行最小权限原则。普通用户只能访问完成业务所需的资源，关键操作由经过授权的用户执行，必要时采用双人审批或二次确认。

（10）安全保存和记录信息。服务器只保存业务所必需的信息，敏感数据应加密存储。系统应记录登录、查询、验证、签名、权限变更和异常操作等日志，并保护日志不被非法删除或修改，以便安全审计和责任追踪。

（11）做好密钥管理。密钥应采用安全随机方式生成，并进行安全存储、分配、使用、更新、备份、撤销和销毁。不同用途应使用不同密钥，避免用同一密钥同时进行加密和消息鉴别。发现密钥泄露、

设备丢失或用户离职时，应立即撤销相关密钥和证书。

（12）设置异常处理机制。当认证失败、签名验证失败、MAC 不一致、消息重复或证书失效时，系统应拒绝该操作并记录日志。对于多次失败、异常查询或大量请求，还应进行限流、告警或临时锁定，防止暴力破解和拒绝服务攻击。

通过上述机制，系统能够防止未授权者读取敏感信息，发现消息篡改，确认参与者身份，防止消息重放，并对重要操作提供不可否认性，从而提高整个系统的安全性。

---

5. 策略、制度和管理型

常见问法：

- 编写一个口令管理策略。
- 制定网络安全管理制度。
- 小企业没有安全团队怎么办？
- 如何开展人员安全教育与审计？

口令与账号管理制度、权限与访问控制制度、网络和设备使用制度、数据管理与备份制度、安全审计制度、人员安全教育制度、漏洞与补丁管理制度、应急响应制度、小企业整体安全管理方案

这种题不是设计密码协议，而是写成**可执行的规则**。

作答角度

> 对象 → 要求 → 周期 → 权限 → 检查 → 违规处理 → 应急恢复

> **明确责任 → 管理账号权限 → 规范日常操作 → 保护设备和数据 → 检查审计 → 培训人员 → 处理安全事件**

为保障单位网络和信息系统安全，应建立覆盖人员、账号、权限、设备、数据、审计和应急处置等方面的网络安全管理制度。

（1）建立安全责任制度。明确网络安全负责人、系统管理员、普通用户和第三方运维人员的职责，实行专人负责和责任追究，避免出现无人管理或职责不清的问题。

（2）加强人员管理。对重要岗位人员进行背景审查，签订保密协议；人员入职时分配必要的账号和权限，岗位变化时及时调整权限，离职时立即停用账号并收回设备、证书和资料。

（3）加强账号和口令管理。所有账号必须设置口令，禁止使用默认口令、空口令和多人共用账号；口令应满足长度和复杂度要求，不得包含用户名、生日等容易猜测的信息；重要账号应采用多因素认证，并限制连续登录失败次数。

（4）实行访问控制和最小权限原则。根据用户岗位和职责分配访问权限，用户只能访问完成工作所必需的资源；重要操作实行审批或双人复核，定期检查并清理长期不用、权限过大和失效的账号。

（5）规范网络使用和边界管理。在网络出口部署防火墙，按照业务需要开放端口和服务；划分办公区、服务器区和对外服务区，限制不同安全区域之间的访问；禁止私自接入未经批准的设备和无线网络。

（6）加强主机、服务器和终端管理。及时安装操作系统和应用软件补丁，关闭不必要的端口、服务和默认账号；安装并更新杀毒软件，定期开展漏洞扫描和安全检查；重要设备由专人管理，禁止随意更改安全配置。

（7）加强数据安全管理。按照数据的重要程度进行分类分级，对敏感数据采取加密存储和加密传输；严格限制数据复制、下载、导出和外发；不得通过个人邮箱、网盘或未经批准的移动存储介质传输重要数据。

（8）建立数据备份与恢复制度。定期备份业务数据、数据库和系统配置，重要数据采用本地备份与异地备份相结合的方式；备份介质应妥善保管，并定期进行恢复测试，确保发生故障或攻击时能够恢复业务。

（9）建立日志记录和安全审计制度。记录用户登录、权限变更、数据访问、系统配置和异常操作等日志；保护日志不被随意删除和修改，定期分析异常登录、越权访问和攻击行为，发现问题及时处理。

（10）建立漏洞和补丁管理制度。持续关注系统和软件漏洞信息，对发现的漏洞进行风险评估；重要漏洞应及时修复，不能立即修复时应采取关闭服务、限制访问或加强监控等临时措施。

（11）开展网络安全教育和培训。定期对员工进行口令安全、钓鱼邮件、恶意链接、数据保密和移动设备使用等培训，提高人员安全意识；通过模拟演练和考核检查培训效果。

（12）建立第三方和外包人员管理制度。第三方人员访问系统前应经过审批，只分配临时和必要的权限；维护过程应进行记录和监督，工作结束后及时撤销账号和权限。

（13）建立安全事件报告和应急响应制度。制定病毒感染、数据泄露、账号被盗、系统入侵和服务中断等事件的应急预案；发生事件后及时采取隔离设备、停止受影响服务、保存日志证据、修复漏洞、恢复数据和上报负责人等措施。

（14）定期开展安全检查与风险评估。定期检查账号权限、设备配置、漏洞补丁、数据备份和日志记录情况，根据检查结果及时整改，不断完善安全管理制度。

二、考试时最实用的总思路

拿到任何场景题，先在草稿上快速写下面四行：

第一步：保护什么

找出场景中的核心资产：

- 身份和账号
- 控制指令
- 用户隐私
- 视频、图像和业务数据
- 服务器和网络设备
- 密钥和证书
- 系统服务的连续运行

第二步：怕什么

至少考虑：

- 窃听
- 篡改
- 冒充
- 重放
- 越权
- 病毒和漏洞利用
- 拒绝服务
- 设备丢失或内部人员攻击

第三步：安全目标是什么

使用这五个关键词检查有没有漏：

1. **机密性**：别人不能看。
2. **完整性**：别人不能悄悄改。
3. **认证性**：确认通信者是谁。
4. **不可否认性**：事后不能抵赖。
5. **可用性**：受到攻击时还能正常工作。

并不是每道题五个都必须写，但“系统建设题”和“通信协议题”最好尽量覆盖。

第四步：用什么措施

从下面的措施库中选择，而不是全部机械抄上：

- 加密
- Hash、MAC、数字签名
- 身份认证、数字证书、MFA
- 访问控制、最小权限
- 时间戳、随机数、序列号
- 防火墙、IDS/IPS
- 补丁、漏洞扫描、关闭无关服务
- 杀毒与恶意代码防护
- 数据备份和恢复
- 日志、审计、监控和告警
- 密钥更新、撤销和销毁
- 安全制度、人员培训和应急响应

三、万能综合题模板

以下模板最适合“请针对某场景设计安全方案”：

> 针对该场景，首先应分析系统中的重要资产以及可能面临的窃听、篡改、冒充、重放、越权、恶意代码和拒绝服务等威胁，并从机密性、完整性、认证性、不可否认性和可用性等方面建立纵深安全防护体系。
>
> （1）在身份安全方面，采用可靠的身份认证机制，重要用户或设备使用数字证书和多因素认证，防止非法主体冒充。
> （2）在权限安全方面，根据角色和任务实行访问控制与最小权限原则，避免越权访问和权限滥用。
> （3）在通信安全方面，使用 SSL/TLS、IPSec 等安全协议，并采用对称加密保护传输数据，防止监听和泄露。
> （4）在完整性方面，对消息使用 MAC/HMAC；对于关键命令或重要文件使用数字签名，保证来源真实、内容未被篡改，并实现抗抵赖。
> （5）在协议设计中加入随机数、时间戳和序列号，防止重放攻击。
> （6）在网络边界部署防火墙，并配合 IDS/IPS 监测扫描、入侵和异常行为。
> （7）及时安装系统和应用补丁，关闭不必要的端口与服务，定期开展漏洞扫描和恶意代码检测。
> （8）做好密钥的生成、存储、分配、更新、撤销和销毁，防止密钥泄露或长期使用。
> （9）对重要数据定期备份，建立冗余和灾难恢复机制，保证系统可用性。
> （10）建立日志审计、安全培训和应急响应制度，发生安全事件时及时发现、隔离、处置并追踪责任。

这个模板可以覆盖大部分“单位、企业、平台、物联网、无人机、服务器”场景，但考试时要替换成具体对象，例如：

- 不要只写“加密数据”，写“加密无人机上传的视频、位置和控制指令”。
- 不要只写“访问控制”，写“普通无人机不得发送返航和投放物资等高级指令”。
- 不要只写“做好备份”，写“备份企业客户数据、业务数据库和系统配置”。

四、不同题型的精简记忆模板

体系建设题

> **物理—边界—主机—应用—数据—用户—审计—管理**

协议设计题

> **认证—协商—加密—完整性—签名—防重放—密钥管理—可用性**

风险与建议题

> **问题是什么—怎么发生—造成什么后果—怎么防**

安全方案设计题

> **参与者—初始化—发送方处理—传输内容—接收方验证—安全分析**

管理策略题

> 规则明确—权限最小—定期检查—日志审计—违规处置—应急恢复

五、这类综合题的得分关键

1. **先贴场景，再写技术。**
   不能只堆“防火墙、加密、签名、认证”这些名词。
2. **每一点最好包含“措施＋作用”。**
   例如：“部署 IDS，实时监测异常流量和攻击行为，弥补防火墙难以发现内部攻击的不足。”
3. **技术必须与安全目标对应。**
   加密对应机密性，MAC 对应完整性和来源认证，签名对应完整性、身份真实性和抗抵赖。
4. **系统题必须有管理措施。**
   只写技术通常不完整，还应写制度、培训、审计、应急和备份。
5. **协议题必须写防重放和密钥管理。**
   这两项最容易漏，也最能体现你不是只会机械写“加密”。
6. **避免所有题都写同一套答案。**
   大框架可以一样，但具体对象、攻击和措施必须根据题目变化。

所以，你的判断基本正确：**综合题表面上场景很多，本质上就是“安全体系建设、威胁与防范、安全通信协议、安全机制设计、管理策略”这几类。**掌握“资产—威胁—安全目标—安全措施—管理保障”的主线，绝大多数题都可以稳定展开。

两种方法都能实现“保密＋认证”，但签名对象不同、验证时机不同，所以适用场景也不同。

一、先签名，后加密

发送方先对明文摘要签名：

$$S_1 = D_{skp}(H(M))$$

再把明文和签名一起加密：

$$C = E_{rko}(M + S_1)$$

接收方先解密：

$$M + S_1 = D_{rkp}(C)$$

再验证：

$$H(M) \stackrel{?}{=} E_{sko}(S_1)$$

适用场景

适合需要证明：发送方确实认可了这份明文内容。

例如：

1. **发送机密合同**
2. Alice向Bob发送一份保密合同。Alice先对合同内容签名，再将“合同＋签名”加密给Bob。Bob解密后，可以证明Alice签署的是这份具体合同。
    - 适合：电子合同、商业报价、投标文件、保密协议、机密公文
3. **发送机密邮件**
4. 邮件内容不能被第三方看到，同时接收方还需要确认邮件确实由发送方发出。先签名后加密能够保证：
    - 邮件内容保密；
    - 内容没有被修改；
    - 发送方不能轻易否认。

主要特点

- 签名直接绑定明文 M；
- 更适合防抵赖；
- 文件和签名都被加密，外界看不到签名；
- 接收方必须先解密，才能验证签名。

二、先加密，后签名

发送方先加密明文：

$$C_1 = E_{rko}(M)$$

再对密文摘要签名：

$$S_1 = D_{skp}(H(C_1))$$

发送：

$$C_1 + S_1$$

接收方先验证：

$$H(C_1) \stackrel{?}{=} E_{sko}(S_1)$$

验证成功后再解密：

$$M = D_{rkp}(C_1)$$

适用场景

适合需要在不知道明文、尚未解密的情况下，先验证密文是否合法的场景。

1. **安全网关先检查再转发**
2. Alice把加密数据发送给Bob，但中间经过一个安全网关。网关不能解密机密内容，却可以验证密文外面的签名，从而判断：
    - 数据是否来自Alice；
    - 密文是否被修改；
    - 是否应该继续转发。

3. 签名错误时，网关可以直接丢弃，不必进行解密。
4. **云端保存加密备份**
5. 用户先加密备份文件，再对加密文件签名，上传到云服务器。云服务器虽然看不到明文，但可以验证：
    - 该加密文件是否由合法用户上传；
    - 保存过程中密文是否损坏或被篡改。
6. 适合：云存储加密备份、加密档案保存、第三方密文托管
7. **设备接收加密指令**
8. 控制中心向设备发送加密控制命令，并对密文签名。设备可以先验证签名：
    - 签名错误，立即拒绝；
    - 签名正确，再进行解密和执行。
9. 这样可以减少设备处理伪造密文的风险。

主要特点

- 签名直接绑定密文 C_1；
- 可以先验证，再解密；
- 中间节点可以验证，但不需要看到明文；
- 对“发送方是否签署了原始文件内容”的证明没有先签名后加密那么直接。

两种方法怎么选

- 强调文件内容和防抵赖，选择：**先签名，后加密**
    - 例如：机密合同、电子公文、投标文件、商业协议
- 强调解密前先确认来源，选择：**先加密，后签名**
    - 例如：安全网关过滤数据、云端密文存储、加密备份完整性验证、设备接收加密指令

一句话记忆：

- **先签名后加密**：在文件上签字，再把文件锁进箱子，适合合同和防抵赖。签字对应合同内容，所以适合证明“我确实签了这份合同”。
- **先加密后签名**：先把文件锁起来，再在箱子外面签字，适合不打开箱子就先验证来源。